

Technology Services

Backup and Recovery Guidelines

Contents

1. Introduction	2
2. Purpose	2
3. Scope	2
4. Backup	2
4.1 Selection of Storage Solutions	3
4.2 Backup Frequency	3
4.3 Documentation	3
4.4 Safe Storage	3
4.5 Immutability	4
4.6 Encryption	4
4.7 Data Retention and Disposal	4
5. Testing	4
6. Cloud Backup Strategies.....	5
7. Recovery.....	5
6.1 Recovering from Legacy Backups.....	5
8. Roles, Responsibilities and Accountabilities	6
9. Related Documents and Information	7
10. Document control	8
Appendix 1 - Definitions	8

1. Introduction

These guidelines are designed to assist in safeguarding institutional data and ensuring its availability during a data loss event. The University requires all data custodians to manage institutional data and records under their control per the University's [Record Management Policy](#) and [Records Management Procedures](#). Authorised users should not rely solely on backups to fulfil their record-keeping responsibilities, as backups are primarily for data recovery in the event of a disaster.

2. Purpose

The purpose of this document is to describe the minimum controls required for data backup regimes to safeguard against data loss due to hardware or software failure, physical disaster, cyber security incidents, or human error. Backups facilitate the availability, restoration, and performance of essential functions during any emergency or situation that may disrupt normal operations. This document supports the University's Information Technology Security Policy by offering practical advice and guidance for backup scenarios.

3. Scope

These guidelines apply to all Southern Cross University users involved in data management. The guidelines cover backup strategies, selection of storage solutions, frequency of backups, backup retention, and detailed recovery procedures.

4. Backup

The University requires that all institutional data be backed up according to the following rules:

- **The 3-2-1 Rule:** Backups should follow the 3-2-1 rule: three copies of data on two different types of storage media, with one copy stored offsite to safeguard against physical disasters.
- **Documentation:** Maintain records of what data is backed up and where it is stored.
- **Recovery Procedures:** Develop, maintain, and update procedures for restoring data.
- **Automated Processes:** Utilise automated backup solutions to reduce human error and ensure consistency. Schedule backups during off-peak hours and verify their completion and integrity by restoring sample files.
- **Importance and Sensitivity:** Assess the importance and sensitivity of the data to determine appropriate backup methods and frequency.
- **Encryption:** Ensure all data is encrypted during storage and transfer to protect against unauthorised access.
- **Configuration and Monitoring:** Configure backup software to include all critical data and systems and monitor automated backups regularly.
- **Regular Verification:** Perform integrity checks and maintain detailed logs of all backup activities.
- **Regular Testing:** Test recovery procedures to ensure reliability in emergencies or disasters.
- **Detailed Logs:** Maintain detailed logs of all backup activities, including the date, time, scope of the backup, and any errors encountered
- **Storage:** Backups are recorded in the corporate records management system according to the [Records Management Policy](#) and [Procedures](#).

4.1 Selection of Storage Solutions

When choosing backup media, consider the specific requirements based on the data's importance and sensitivity. Options include:

- **Cloud Storage:** Easily accessible, scalable, and often includes advanced security features like encryption and compliance tools.
- **Internal Hard Disk Drives:** Fast access and integration with existing systems but vulnerable to physical damage and malware.
- **Removable Media:** External hard drives and SSDs offer portability and high storage capacity, while magnetic tape is cost-effective for large volumes but slower in access.

4.2 Backup Frequency

To maintain data integrity and ensure continuous protection, adhere to the following schedule:

- **Daily Backups:** Provides a granular recovery point for critical systems and frequently changing data.
- **Weekly Backups:** Balancing protection and storage efficiency for systems with moderate changes.
- **Monthly Backups:** These are for archival purposes and infrequently changing data, providing long-term retention.

4.3 Documentation

Proper documentation ensures clear, consistent, and repeatable backup and recovery processes:

- **Maintain Detailed Logs:** Keep logs of all backup activities, including dates, data backed up, and errors encountered.
- **Document Procedures:** Include step-by-step instructions for backups and restores, ensuring consistency.
- **Regular Updates:** Review and update documentation regularly to reflect changes in technologies and procedures.
- **Compliance Records:** Maintain records to demonstrate compliance with regulatory and business requirements.
- **Recovery Objectives:** Document and regularly review Recovery Point Objectives (RPO) and Recovery Time Objectives (RTO) to ensure they meet the institution's requirements and are aligned with the overall business continuity plan.

4.4 Safe Storage

Ensure the safe storage of backups by:

- **Offsite Storage:** Store one copy at a secure offsite location to protect against physical disasters.
- **Physical Security:** Use access-controlled environments for physical media to prevent unauthorised access.
- **Environmental Controls:** Maintain appropriate conditions to preserve the integrity of physical media.

4.5 Immutability

Protect backups against unauthorised modifications and deletions by:

- **Access Controls:** Implement strict controls to ensure only authorised personnel can modify or delete backups.
- **Immutable Backups:** Utilise technologies to make backup data unchangeable for a specified period.
- **Audit Trails:** Maintain detailed audit trails to monitor access and backup changes.

4.6 Encryption

Protect backup data by:

- **Data at Rest:** Encrypt all backup data while stored.
- **Data in Transit:** Use strong encryption protocols for data transfer.
- **Encryption Key Management:** Implement robust practices, including regular key rotation and secure key storage.

4.7 Data Retention and Disposal

Proper retention and disposal of backups ensure compliance and data integrity:

- **Retention:** Follow the university's Records Management Policy and Procedures to determine retention periods based on data type and legal requirements.
- **Short-Term Retention:** Keep daily backups for at least one week.
- **Medium-Term Retention:** Retain weekly backups for a minimum of one month.
- **Long-Term Retention:** Keep monthly backups for at least one year.
- **Archival Retention:** Preserve data indefinitely if required for legal or regulatory reasons.
- **Disposal:** Securely destroy backups after retention periods end, ensuring data is irrecoverable.

5. Testing

Regularly test backups to confirm reliability and successful data restoration:

- **Regular Testing Schedule:** Conduct tests monthly or quarterly.
- **Test Restores:** Perform full and partial restorations to verify completeness and integrity.
- **Verification and Validation:** Conduct integrity checks and functional testing post-recovery.
- **Documentation:** Maintain logs of all tests and review results for continuous improvement.
- **Continuous Improvement:** Update procedures based on test outcomes and provide ongoing staff training.

6. Cloud Backup Strategies

- **Redundancy:** Utilise cloud-native redundancy features such as multi-region and multi-zone replication to protect against data loss and regional outages.
- **Service-Level Agreements (SLAs):** Ensure cloud service providers (CSPs) offer SLAs that meet the University's requirements for data availability, recovery time objectives (RTO), and recovery point objectives (RPO).
- **Multi-Location Backups:** Store backup data across multiple geographic regions to mitigate the risk of regional outages or disasters.
- **Access Control:** Enforce strict role-based access control (RBAC) to limit access to backup data to authorised personnel only. Regularly review and update access permissions.
- **Audit Trails:** Maintain detailed audit logs to monitor access and changes to backup data, supporting accountability and compliance.
- **Regulatory Compliance:** Ensure backup processes comply with relevant legal, regulatory, and university policies, including data retention and privacy requirements.
- **Documentation:** Maintain comprehensive documentation of backup configurations, schedules, processes, and recovery procedures. Regularly update documentation to reflect changes in cloud services or backup requirements.
- **Integration with DR Plans:** Ensure cloud backup solutions are integrated with the University's overall disaster recovery (DR) and Business Continuity plans.
- **Rapid Recovery:** Develop and maintain procedures for rapid recovery from cloud backups, prioritising critical systems and data. Ensure clear communication channels and responsibilities during recovery efforts.

7. Recovery

Detailed steps for data recovery:

- **Identifying Data Loss:** Implement continuous monitoring and immediate reporting.
- **Recovering Data:** Follow documented procedures, prioritise critical systems, and verify restored data.
- **Post-Recovery Actions:** Conduct root cause analysis, update recovery plans, and maintain compliance documentation.

6.1 Recovering from Legacy Backups

When restoring data from older technologies, follow these guidelines:

- **Availability:** Ensure legacy hardware and software are available as per retention periods.
- **Compatibility:** Verify data compatibility with current systems; use emulators if needed.
- **Data Transfer:** Promptly transfer data to modern storage solutions to prevent loss.
- **Integrity Check:** Conduct integrity checks during and after transfer.
- **Documentation:** Record the restoration process and resolve issues, maintaining compliance with university policies.

8. Roles, Responsibilities and Accountabilities

Role	Responsibility
Director, Cyber Security	• Approve any exemptions Technology Security Policy or this guideline.
Cyber Resilience Team (CRT)	• Consult on the exemptions to the Information Technology Security Policy or associated guidelines. • Develop, maintain and improve guidelines • Monitor and report on compliance to measure the effectiveness. • Support the development and testing of any backup and recovery procedures.
Infrastructure teams	• Implement and maintain infrastructure security in line with policy and guidelines • Develop, maintain and improve Backup and Recovery procedures for SCU infrastructure. • Develop, maintain and improve Test backup and recovery procedures.
Application Owners	• Implement and develop applications in line with policy and guidelines. • Develop, maintain and improve Backup and Recovery procedures for the appropriate applications. • Participate in backup and recovery test procedures

9. Related Documents and Information

Protecting Data from Ransomware and Other Data Loss Events. (National Institute of Standards and Technology.)	https://www.nist.gov/publications/protecting-data-ransomware-and-other-data-loss-events-guide-managed-service-providers
Australian Cyber Security Centre. (2023). Guidelines for System Management. Retrieved from ACSC Guidelines	https://www.cyber.gov.au/resources-business-and-government/essential-cyber-security/ism/cyber-security-guidelines/guidelines-system-management
CISA Data Backup Option	https://www.cisa.gov/sites/default/files/publications/data_backup_options.pdf
NCCoE Protecting Data	https://www.nccoe.nist.gov/sites/default/files/legacy-files/msp-protecting-data-extended.pdf
Information Technology Security Policy	
Record Management Policy	https://policies.scu.edu.au/view.current.php?id=00106
Records Management Procedures	https://policies.scu.edu.au/document/view-current.php?id=304

10. Document control

These guidelines shall be subject to periodic review to ensure currency and relevancy.

Document owner:		Director, Cyber Security		
Document approver:		Director, Cyber Security		
Classification:		Sensitive		
Compliance				
Essential 8		Regular backups: ML1, ML2, ML3		
ISM		Principle: Protect: P9 and Respond: R3 Controls: ISM-1510, ISM-1547, ISM-1548, ISM-1511, ISM-1810, ISM-1811, ISM-1812, ISM-1813, ISM-1705, ISM-1706, ISM-1814, ISM-1707, ISM-1708, ISM-1515		
NIST		PR.IP-4		
Revision				
Version	Approved by	Reason for Change	Approval date	Review due
V0.1	N/A	Initial Draft		11/06/2024
V0.2	N/A	CAG Review		
V1	Director, Cyber Security	Release	08 Jul 2024	01 Jun 2025

Appendix 1 - Definitions

Term	Definition
3-2-1 Rule	A best practice in backup strategy where three copies of data are maintained on two different types of storage media, with one copy stored offsite
Backup	The process of copying data from a primary location to a secondary location to protect against data loss
Backup Media	Devices or storage locations are used to hold backup data. Examples include cloud storage, internal hard drives, external hard drives, SSDs, optical discs, and magnetic tape.
Cloud Storage	Online storage is where data is saved on remote servers accessed via the internet.
Data Encryption	The process of converting data into a coded format to prevent unauthorised access.
Immutable Backups	Backup data that cannot be altered or deleted for a specified period, protecting against accidental or malicious changes.
Integrity Checks	Processes to ensure that data has not been altered or corrupted.
Physical Security	Measures to protect hardware and physical storage media from theft, damage, or unauthorised access
Role-Based Access Control (RBAC)	A system of managing access to resources based on the roles of individual users within an organisation.

Verification	The process of confirming that backup data is complete, accurate, and usable.
Checksum	A value used to verify the integrity of a file or data by detecting errors that may have been introduced during its storage or transmission.
Disaster Recovery (DR)	A set of policies and procedures to enable the recovery or continuation of vital technology infrastructure and systems following a disaster.
Business Continuity	The planning and preparation to ensure that an organization can continue to operate in case of serious incidents or disasters
Recovery Time Objective (RTO)	The maximum acceptable amount of time to restore a function after a disaster.
Recovery Point Objective (RPO)	The maximum acceptable amount of data loss measured in time.
Service-Level Agreement (SLA)	A contract between a service provider and a customer that specifies what services the provider will furnish and defines the performance standards the provider is obligated to meet.
Legacy Backups	Older backups created with obsolete or outdated technology.